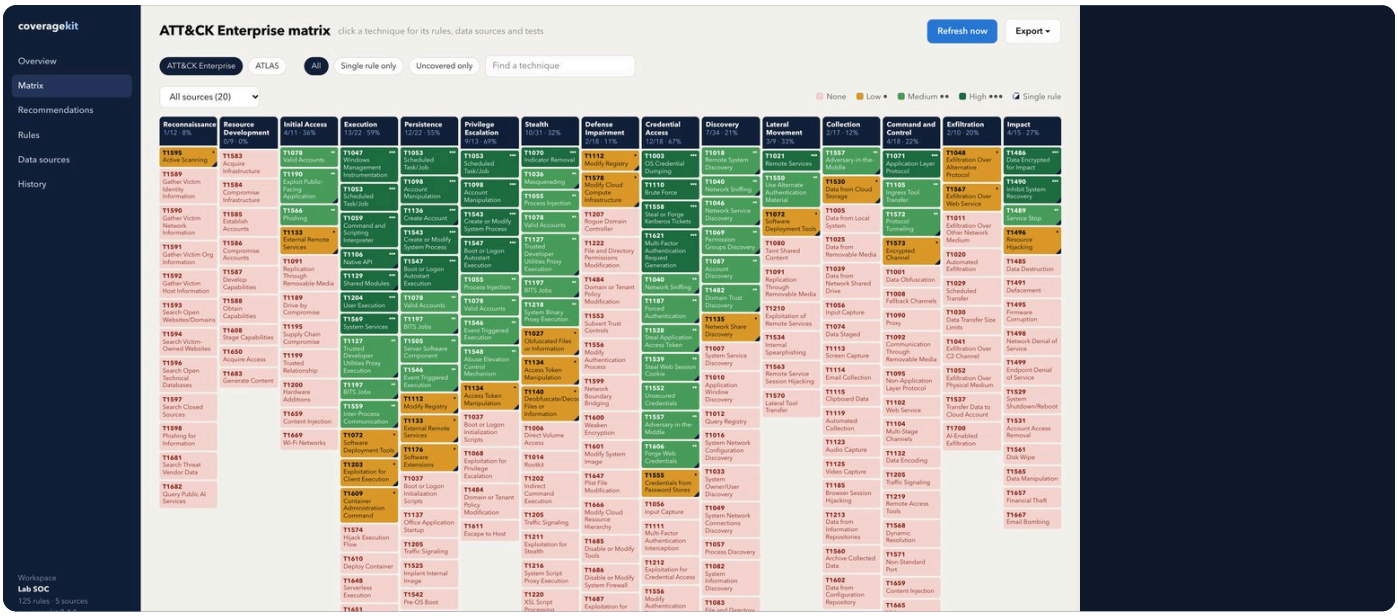
Leandro F. Juárez · Proyecto

mitre-coverage-kit

Lo desarrollé yo como proyecto de código abierto, con el objetivo de que un SOC pueda medir su cobertura de detección en lugar de suponerla.



ENLACES

github.com/lfjuarez/mitre-coverage-kit

El problema

La cobertura de detección suele ser una creencia ("cubrimos credential access") que nadie puede medir. mitre-coverage-kit la convierte en una medición.

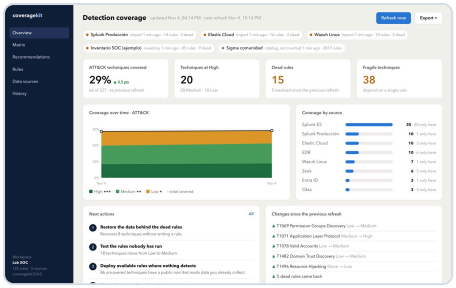
En detalle

Es una herramienta en Python (`coveragekit`) que lee las reglas de uno o varios SIEM, desde archivos exportados o directamente desde sus APIs (Splunk Enterprise Security, Elastic Security, Wazuh, Microsoft Sentinel o Sigma), puntúa cada técnica de MITRE ATT&CK Enterprise y de MITRE ATLAS de 0 a 3 con un semáforo suave (sin cobertura, baja, media, alta, con marcas aptas para daltonismo), exporta una capa para ATT&CK Navigator y un mapa de calor en SVG, y genera informes en HTML, PDF, Excel, CSV, Markdown y JSON. También lista las reglas muertas: las que están habilitadas pero nunca podrían disparar porque falta su fuente de datos.

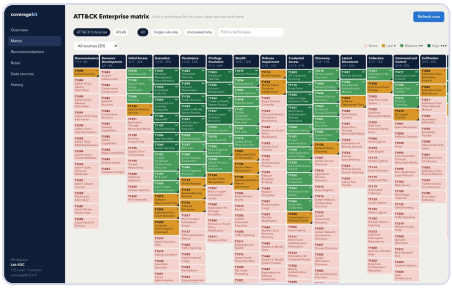
Con `coveragekit serve` levanta una aplicación web local que refresca cada fuente según un cronograma y deja que el SOC navegue el resultado: cifras clave y su variación, cobertura en el tiempo y por fuente, las matrices completas de ATT&CK y ATLAS con filtros, un panel por técnica con sus reglas, los datos que le faltan a cada una y sus tests de Atomic Red Team, recomendaciones, historial con diff entre refrescos y exportación. Los catálogos (por ejemplo, el repositorio SigmaHQ) son reglas disponibles pero no desplegadas: nunca cuentan como cobertura, pero para cada técnica sin detección se listan las reglas públicas que la cubrirían, primero las que leen datos que ya se recolectan.

Incluye ATT&CK Enterprise v20 y ATLAS v5.6, un laboratorio que corre los importadores contra Splunk, Elastic y Wazuh reales en contenedores, y se probó contra el ruleset completo de Wazuh (4.499 reglas) y el repositorio público de SigmaHQ (3.162 reglas). Algo similar, a escala masiva, lo implementé en empresas muy grandes: medición y seguimiento de cobertura sobre SIEM de distintos proveedores y en distintos entornos (cloud, on-premise e híbridos), con una batería de tests automática y seguimiento de cobertura por metadatos.

Licencia MIT, con tests e integración continua en cada push.



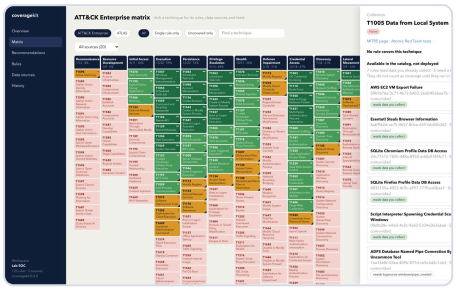
Resumen: cifras clave y su variación



Matriz ATT&CK con el semáforo de cobertura



Panel por técnica: reglas, datos faltantes y tests



Catálogo: reglas públicas que cubrirían cada hueco

Capturas, documentos y preguntas en leandrojuarez.info/projects?lang=es#mitre-coverage-kit-codigo-abierto